WANDR TRAVEL GROUP

Cybersecurity Policy

Mercy Oji

February 8, 2026

University of Dallas
CYBS 8396: Strategic Cybersecurity Practicum

Table of Contents

1. **Executive Summary**
2. **Overview of PCI DSS and GDPR**
    - 2.1 PCI DSS
    - 2.2 GDPR
3. **Access Control and Authentication Policy (System-Specific Security Policy)**
4. **Data Protection and Privacy Policy (Issue-Specific Security Policy)**
5. **Secure Remote Access Policy (Issue-Specific Security Policy)**
6. **Incident Response and Breach Notification Policy (Issue-Specific Security Policy)**
7. **Reducing Cybersecurity Breaches: Discussion and Plan**
8. **References**

Executive Summary

Wandr Travel Group (WTG) is a fictional small-to-medium-sized travel technology company that offers web and mobile applications, supported by an AI-powered travel companion that delivers personalized travel recommendations. Customers create accounts, submit personal information, and pay for flights, hotels, and travel packages directly on the platform. WTG's business strategy focuses on leveraging artificial intelligence and digital convenience to deliver personalized travel experiences while expanding its customer base across global markets.

As the Chief Information Security Officer (CISO), I am responsible for designing and documenting foundational cybersecurity policies aligned with WTG's business model, regulatory obligations, and risk profile. This report serves as a policy-mapping and governance exercise, identifying applicable regulations and translating their requirements into enforceable policies. Information security policies are management directives that communicate organizational expectations, guide employee behavior, and establish baselines for compliance, enforcement, and audit activities (White & Mattord, 2018). Without clearly defined and consistently enforced policies, cybersecurity controls are applied unevenly, increasing the risk of breaches and regulatory noncompliance.

Two regulations were selected as most applicable to WTG: the Payment Card Industry Data Security Standard (PCI DSS) and the General Data Protection Regulation (GDPR). PCI DSS was selected because WTG processes payment card transactions as a core business function. Compliance is mandatory and directly affects access control for payment systems, remote access security, and incident handling involving cardholder data (Payment Card Industry Security Standards Council [PCI SSC], 2022). GDPR was selected because WTG collects and processes personal data and may serve customers in the European Union. GDPR imposes strict requirements for lawful data processing, confidentiality, and breach notification, making it a critical regulatory driver (European Parliament & Council of the European Union, 2016).

Given these regulatory obligations and WTG's risk profile, four cybersecurity policies were selected: Access Control and Authentication, Data Protection and Privacy, Secure Remote Access, and Incident Response and Breach Notification. These policies address the most common root causes of cybersecurity incidents, including unauthorized access, data exposure, insecure remote connectivity, and delayed incident response.

Access control and authentication measures, including role-based access control, least-privilege principles, and multi-factor authentication, prevent unauthorized access to sensitive systems. Data protection measures, including data minimization and retention controls, reduce the impact of breaches involving personal and payment data. Secure remote access measures address high-risk attack vectors by enforcing strong authentication and encrypted connections. Incident response and breach notification measures ensure that WTG can respond quickly, contain damage, and meet regulatory reporting obligations when incidents occur.

This approach aligns with the cybersecurity governance principles discussed in the course text and lectures, emphasizing policy-driven risk management, regulatory alignment, and enforceable controls as the foundation of an effective cybersecurity program (White & Mattord, 2018).

The report explains why breaches persist despite existing cybersecurity policies, examines factors such as human error, inadequate enforcement, and evolving threats, and presents a plan to reduce breach incidents. These policies form the foundation of WTG's cybersecurity program, guiding employee behavior, establishing management accountability, supporting audit and compliance activities, and strengthening the organization's ability to prevent, detect, and respond to cybersecurity threats in line with its business strategy and regulatory obligations.

Overview of PCI DSS and GDPR

2.1 **Payment Card Industry Data Security Standard (PCI DSS)**

The Payment Card Industry Data Security Standard (PCI DSS) is an industry-mandated framework that protects cardholder data and reduces payment fraud. It applies to any organization that stores, processes, or transmits payment card information, setting requirements for access control, authentication, encryption, monitoring, and incident response (Payment Card Industry Security Standards Council [PCI SSC], 2022). Noncompliance can lead to financial penalties, higher transaction fees, reputational damage, and loss of card processing capabilities. For WTG, PCI DSS compliance is essential because electronic payments are a core business function. The standard guides the management of payment system access, the securing of remote access, and the handling of payment data incidents.

2.2 General Data Protection Regulation (GDPR).

The General Data Protection Regulation (GDPR) is a comprehensive data protection regulation governing the processing of personal data of individuals in the European Union. It applies to organizations outside the EU that offer services to EU residents (European Parliament & Council of the European Union, 2016). WTG collects personal data, including names, contact information, travel preferences, and booking history, to deliver personalized experiences. The GDPR requires lawful, transparent processing; limits data collection and retention; protects confidentiality; and mandates timely breach notification. Non-compliance exposes organizations to regulatory fines and reputational damage. Given its AI-driven personalization, which increases the sensitivity and volume of personal data processed, compliance is critical for WTG.

Policy 1: Access Control and Authentication Policy - System-Specific Security Policy (SysSP)

Access control policies establish management expectations for protecting systems and data and provide a measurable basis for enforcement and audit activities (White & Mattord, 2018). This policy supports PCI DSS and GDPR compliance by limiting access to sensitive systems and personal data.

PCI DSS requires restricting access to cardholder data environments based on business need-to-know and enforcing strong authentication (PCI SSC, 2022). GDPR requires that personal data be accessible only to authorized individuals (European Parliament & Council of the European Union, 2016). These controls reduce the likelihood of unauthorized access and limit the impact of compromised credentials.

This policy reflects management's intent to reduce unauthorized access, prevent misuse of the system, and ensure user accountability. Access control is foundational because authentication and authorization failures are among the most common root causes of data breaches and payment fraud (IBM Security & Ponemon Institute, 2025).

Because WTG processes payment transactions and personal data through unified web and mobile platforms, ineffective access controls would expose the organization to regulatory penalties, financial loss, and reputational damage, making this policy critical for compliance and risk management.

Required Policy Elements

Role-Based Access Control (RBAC): RBAC grants system and data access based on defined job responsibilities. PCI DSS requires restricting cardholder data access to business need-to-know, while GDPR mandates limiting access to personal data to authorized individuals for legitimate purposes (Payment Card Industry Security Standards Council, 2022; European Parliament & Council of the European Union, 2016). At WTG, RBAC reduces the likelihood that employees or contractors access payment systems or customer data unrelated to their roles, thereby limiting insider misuse and the impact of compromised credentials.

Multi-Factor Authentication (MFA): MFA is required for all privileged, administrative, and remote access to WTG systems. PCI DSS mandates strong authentication for administrative access and remote connections to payment processing systems (Payment Card Industry Security Standards Council, 2022). MFA significantly mitigates risks from phishing, credential theft, and password reuse, which can lead to data breaches (IBM Security & Ponemon Institute, 2025).

Least Privilege Enforcement: Least privilege ensures users receive only the access required to perform their job functions, supporting PCI DSS access-restriction requirements and GDPR's data minimization and confidentiality principles (Payment Card Industry Security Standards Council, 2022; European Parliament & Council of the European Union, 2016). For WTG, this reduces the organization's attack surface and limits damage from compromised accounts or malicious insiders. Periodic access reviews demonstrate due diligence and provide auditors with evidence of active management of access rights (White & Mattord, 2018).

Account Provisioning and De-Provisioning Controls: Formal account provisioning and de-provisioning ensure that system access is approved and documented, and promptly revoked when roles change or employment ends. At WTG, failure to promptly revoke access could

result in unauthorized access to customer data or payment systems, increasing security and compliance risks.

By clearly defining how access is authorized, authenticated, reviewed, and revoked, this policy guides employee behavior, supports regulatory compliance, and reduces incidents of unauthorized access. As a System-Specific Security Policy, it provides technical governance for WTG's cybersecurity program and reinforces management's commitment to safeguarding customer trust and business operations.

Policy 2: Data Protection and Privacy Policy - Issue-Specific Security Policy (ISSP)

The Data Protection and Privacy Policy outlines WTG's expectations for collecting, processing, storing, sharing, retaining, and protecting personal, sensitive, and payment-related data throughout its lifecycle. As a digital travel technology company delivering AI-driven, personalized experiences, WTG must balance innovation with responsible data stewardship. Information security policies define acceptable behavior, protect organizational assets, and establish the foundation for enforcement and audit activities.

This policy reflects management's intent to protect customer privacy, mitigate data breach risks, and ensure compliance with data protection and payment security regulations. Given the volume and sensitivity of the data processed, including customer profiles, travel preferences, booking history, and payment information, inadequate data protection would expose WTG to regulatory penalties, reputational harm, and loss of customer trust.

Required Policy Elements

Data Classification and Handling Requirements: Data classification identifies sensitivity levels and defines handling procedures. GDPR requires protecting personal data based on risk, while PCI DSS emphasizes protecting cardholder data environments (European Parliament & Council of the European Union, 2016; Payment Card Industry Security Standards Council, 2022). At WTG, classifying customer profiles, payment information, and internal analytics helps employees understand proper access, storage, and sharing practices, thereby reducing accidental disclosure.

Encryption of Sensitive Data: Encryption at rest and in transit is fundamental to GDPR and PCI DSS compliance. PCI DSS mandates encryption of cardholder data transmitted over open networks, while GDPR requires appropriate technical measures to protect the confidentiality of personal data (Payment Card Industry Security Standards Council, 2022; European Parliament & Council of the European Union, 2016). For WTG, encryption mitigates risks from intercepted or improperly accessed data, particularly in cloud-based and mobile environments.

Data Minimization and Retention Limits: Personal and sensitive data are collected only for legitimate business purposes and retained only as necessary. Storing sensitive authentication data (SAD)—including card verification codes, PINs, and full magnetic stripe data—is prohibited. PCI DSS Requirement 3.3 prohibits SAD storage after authorization (Morse, 2008). Data must not be retained beyond required periods. For example, dormant customer

profiles may be purged after 3 years, and credit card PANs deleted after 2 days or once payment is processed. PCI DSS Requirement 3.2.1 requires storing data only as long as necessary for legal, regulatory, or business needs. This aligns with the GDPR's storage limitation principle (Article 5(1)(e)). When data is no longer needed, it must be securely deleted from active systems, backups, and archives using methods such as shredding for physical media or cryptographic wiping for electronic data.

Privacy Rights Management: Enables individuals to access, correct, and request deletion of their personal data. The GDPR requires organizations to support these rights and respond to requests in a timely, documented manner (European Parliament & Council of the European Union, 2016). For WTG, clear processes for handling privacy requests reinforce transparency, support compliance, and demonstrate ethical data stewardship.

Data breaches involving personal information impose significant financial and reputational costs (IBM Security & Ponemon Institute, 2025). This policy reduces WTG's exposure by limiting unnecessary data retention, enforcing encryption, and ensuring consistent handling of sensitive data. WTG's Data Retention Policy enforces the principle "if you don't need it, don't store it," reducing breach risk by limiting retained data and purging old records.

Policy 3: Secure Remote Access Policy - Issue-Specific Security Policy (ISSP)

Remote access is a significant attack vector for digital organizations, particularly those using cloud platforms and remote work models. Small and medium-sized organizations are especially vulnerable to remote-access attacks because of limited security resources and greater reliance on cloud services (CrowdStrike, 2005). This policy reduces the risk of unauthorized system access and supports regulatory compliance.

The Secure Remote Access Policy sets WTG’s expectations for securely accessing company systems, applications, and data from external networks and locations. As a travel technology organization that supports remote employees, cloud-based administration, and third-party vendors, WTG must ensure that remote connectivity does not introduce unacceptable cybersecurity risk. Security policies articulate management’s intent and guide acceptable behavior by defining how organizational assets are protected and monitored.

For WTG, insecure remote access could allow attackers to bypass perimeter controls and access payment systems or personal data. This policy is therefore a critical control for both compliance and risk reduction.

Required Policy Elements

Multi-Factor Authentication: Multi-factor authentication (MFA) must be enforced for all remote access to WTG systems, especially for administrative and privileged users. PCI DSS mandates strong authentication for remote access to systems involved in payment processing, while GDPR requires safeguards that reduce the risk of unauthorized access to personal data (Payment Card Industry Security Standards Council, 2022; European Parliament & Council of the European Union, 2016). MFA significantly reduces the likelihood that stolen or weak

credentials can compromise systems, addressing a common root cause of remote access breaches (IBM Security & Ponemon Institute, 2025).

Secure Communication Channels: Remote access connections must use approved secure communication technologies, such as encrypted virtual private networks (VPNs) or secure access gateways. For WTG, enforcing encrypted remote connections protects customer data and administrative credentials from interception or manipulation.

Remote Access Logging and Monitoring: All remote access activity must be logged, monitored, and periodically reviewed. PCI DSS requires organizations to track and monitor access to network resources and cardholder data to detect suspicious activity (Payment Card Industry Security Standards Council, 2022). Continuous monitoring provides visibility into remote access behavior and supports incident detection and forensic investigations.

Session Management Controls: Remote access sessions must implement inactivity timeouts and automatic session termination. These controls limit the risk of unauthorized access from unattended or hijacked sessions. For WTG, these controls reduce the likelihood that remote access sessions can be exploited to gain persistent access to systems.

Risk Reduction, Auditability, and Program Impact: Remote access remains a high-risk area for small and medium-sized organizations because of increased reliance on cloud platforms and limited security resources (CrowdStrike, 2005). This policy directly reduces WTG's exposure by enforcing strong authentication, encryption, monitoring, and session controls across all remote access pathways.

Each policy element is measurable and auditable, enabling auditors to verify compliance using authentication logs, access records, and monitoring reports. By clearly defining how remote access must be secured, this policy guides employee and vendor behavior, supports regulatory compliance, and strengthens WTG's overall cybersecurity posture. As an Issue-Specific Security Policy, it complements access control, data protection, and incident response policies, forming a cohesive, governance-driven cybersecurity program.

Policy 4: Incident Response and Breach Notification Policy - Issue-Specific Security Policy (ISSP)

The Incident Response and Breach Notification Policy outlines WTG's expectations for identifying, responding to, containing, and reporting cybersecurity incidents that may affect company systems, customer data, or payment processing environments. As a digital travel platform that processes online payments and stores personal data, WTG must be prepared to respond quickly and effectively to security incidents to minimize operational disruption, financial loss, and regulatory exposure.

Delayed detection and response significantly increase breach-related costs and operational disruption (IBM Security & Ponemon Institute, 2025).

This policy applies to all employees, contractors, third-party service providers, and systems involved in detecting, investigating, responding to, and reporting cybersecurity incidents,

including those affecting the web application, mobile application, AI-powered travel companion, cloud services, and payment-processing systems.

GDPR requires organizations to detect and assess personal data breaches and notify supervisory authorities and affected individuals within defined timeframes when required. PCI DSS requires organizations to maintain an incident response plan to address security breaches involving cardholder data. A formal incident response and breach notification policy is therefore essential for meeting regulatory obligations and reducing the impact of security incidents.

The following elements must be included and enforced to ensure effective incident response and regulatory compliance:

Incident Identification and Classification: Security events must be identified, documented, and classified by severity, scope, and potential impact on systems, personal data, and payment environments.

Defined Roles and Escalation Procedures: Clear roles and responsibilities must be established for incident response, including escalation paths to management, legal counsel, and external partners as needed.

Breach Notification Requirements: Breaches involving personal data or payment information must be promptly assessed and reported to regulators, payment brands, and affected individuals in accordance with applicable regulatory and contractual timelines.

Incident Containment and Recovery: Procedures must be in place to contain incidents, limit damage, restore affected systems, and preserve evidence for investigation and audit.

Post-Incident Review and Reporting: After resolution, all significant incidents must be reviewed to identify root causes, document lessons learned, and implement corrective actions to prevent recurrence.

Reducing Cybersecurity Breaches: Discussion and Plan

Despite widespread adoption of cybersecurity policies, organizations continue to experience breaches because policies are often treated as compliance artifacts rather than operational governance tools. Policies often exist on paper but are poorly enforced, inconsistently applied, or misaligned with business processes and threat environments. Human error, excessive access privileges, insecure remote access practices, and delayed incident detection remain common contributors to security incidents. Rapidly evolving technologies, such as cloud computing, mobile platforms, and artificial intelligence, introduce new attack surfaces that outdated or generic policies fail to address.

Breaches persist because of the gap between policy intent and employee behavior. When employees do not understand the purpose of cybersecurity policies or see them as obstacles rather than safeguards, controls are bypassed or ignored. Organizations that fail to establish clear accountability for policy enforcement struggle to maintain consistent security practices.

Well-written policies fail to reduce real-world risk if they are not embedded in daily operations, supported by leadership, and reinforced through monitoring and review. Policies must be clearly communicated so employees at all levels understand why they matter and are held accountable for compliance (Greenberg, 2015).

At WTG, the plan to reduce cybersecurity breaches treats policies as enforceable governance mechanisms rather than static documents. The Access Control and Authentication Policy addresses common breach vectors by enforcing role-based access, least-privilege principles, and multi-factor authentication. These controls limit unauthorized access and reduce the risk that compromised credentials will be used to access sensitive systems that process payments and store customer data.

The Data Protection and Privacy Policy mitigates breach impact by minimizing the amount of sensitive data retained and ensuring that personal and payment-related data is encrypted throughout its lifecycle. By limiting unnecessary data exposure and enforcing clear handling requirements, WTG reduces regulatory risk and potential harm to customers. This approach aligns security controls with privacy obligations and ethical data stewardship.

The Secure Remote Access Policy addresses a common source of security incidents by mandating strong authentication, encrypted connections, session controls, and continuous monitoring. These measures reduce the likelihood of attackers exploiting remote access channels to achieve persistent system access.

The Incident Response and Breach Notification Policy ensures that WTG can respond promptly to incidents, contain damage, and comply with regulatory and contractual obligations. Defined roles, escalation procedures, and post-incident reviews enable continuous improvement and reduce the long-term impact of security events.

Together, these policies establish a governance-driven cybersecurity foundation that reduces the likelihood of breaches by addressing root causes, strengthening enforcement, and aligning security practices with WTG's business operations and risk tolerance.

References

CrowdStrike. (n.d.). *Cybersecurity assessment for small and medium-sized businesses*. https://www.crowdstrike.com/en-us/solutions/small-business/

European Parliament & Council of the European Union. (2016). *Regulation (EU) 2016/679 (General Data Protection Regulation)*. https://eur-lex.europa.eu/eli/reg/2016/679/oj

Greenberg, A. (2015, April 1). Human error cited as leading contributor to breaches, study shows. SC World. https://www.scworld.com/news/human-error-cited-as-leading-contributor-to-breaches-study-shows

IBM Security & Ponemon Institute. (2025). *Cost of a data breach report 2025*. https://www.ibm.com/reports/data-breach

LRQA. (n.d.). *How to build a strategic cybersecurity plan*. https://www.lrqa.com/en/insights/articles/how-to-build-a-strategic-cyber-security-plan/

Morse, E. A., & Raval, V. (2008). PCI DSS: Payment card industry data security standards in context. *Computer Law & Security Review*, *24*(6), 540–554.

National Institute of Standards and Technology. (2024). *Cybersecurity framework (CSF) 2.0*. https://www.nist.gov/cyberframework

Payment Card Industry Security Standards Council. (2022). *Payment Card Industry data security standard: Requirements and security assessment procedures (Version 4.0)*. https://www.pcisecuritystandards.org

Splunk Inc. & Oxford Economics. (2025, January 23). *The CISO Report 2025: CISOs and their boards of directors — research on goals, priorities, and business strategy*. Splunk. https://www.prnewswire.com/news-releases/splunk-report-cisos-gain-influence-in-the-c-suite-and-boardrooms-worldwide-302357998.html

Splunk Inc. (2025). *The power of partnerships between CISOs and their boards*. Splunk Blog. https://www.splunk.com/en_us/blog/leadership/the-power-of-partnerships-between-cisos-and-their-boards.html

White, M. E., & Mattord, H. J. (2018). *Management of information security* (6th ed.). Cengage Learning.